



Vulnerability Assessment Report



Prepared by Gedhala Jyothi
Future Interns - Cyber Security Task 1
September 2026

EXECUTIVE SUMMARY

Target: demo.testfire.net

Assessment Type: Read-Only / Passive Security Assessment

A read-only security assessment was conducted against the publicly accessible demo website demo.testfire.net.

The assessment focused on:

- Network exposure
- HTTP/HTTPS security
- Response security headers
- Cookie security attributes
- TLS/certificate configuration

Several security observations were identified, including an expired TLS certificate, security headers not observed in the captured response, HTTP accessibility, and externally visible services.

No exploitation, brute-force attacks, authentication bypass, denial-of-service testing, or other intrusive activities were performed.

Assessment Objective: Identify observable security weaknesses, classify their risk, and provide practical remediation recommendations.

SCOPE & ETHICS

In Scope

- Public-facing website pages
- HTTP/HTTPS response headers
- Cookie security attributes
- TLS/certificate observations
- Basic network exposure analysis

Allowed Activities

- Passive scanning
- Header checks
- Configuration analysis
- Browser-based inspection

Not Allowed

- Login bypass
- Exploitation
- Brute-force attacks
- Denial-of-Service (DoS)

Assessment Principle

The assessment was conducted as a security audit, not an attack. No intrusive or destructive testing was performed.





METHODOLOGY

RECONNAISSANCE

Reviewed the publicly accessible target and identified externally visible services.

HTTP/HTTPS ANALYSIS

Inspected response status, server information, TLS behavior, and security-related headers.

COOKIE ANALYSIS

Reviewed session-cookie security attributes using browser Developer Tools.

PASSIVE SECURITY REVIEW

Used non-intrusive inspection methods only. No exploitation or active attacks were performed.

TOOLS



Nmap

Purpose: Basic port and network exposure analysis

Result: Identified externally visible TCP services.



cURL

Purpose: HTTP/HTTPS response inspection

Result: Reviewed status, server information, cookies and response headers.



Browser DevTools

Purpose: Header and cookie analysis

Result: Reviewed response headers and session-cookie attributes.



OWASP ZAP

Purpose: Passive web security review

Mode: Safe / Passive

Note: No active scanning or exploitation performed.

Assessment Approach

Observe → Document → Classify → Remediate

ASSESSMENT FINDINGS

ID	Finding	Risk
F-01	Expired TLS Certificate	Medium
F-02	Security Headers Not Observed	Medium
F-03	HTTP Service / Plaintext Access	Medium
F-04	TCP/8080 Externally Visible	Low
F-05	Server Technology Disclosure	Low
F-06	Cookie Attribute Inconsistency	Low

F-01 — EXPIRED TLS CERTIFICATE

Risk Level:  MEDIUM

Observation:

The HTTPS endpoint presented an expired TLS certificate during normal browser access.

Why It Matters :

An expired certificate can trigger browser warnings, reduce user trust, and disrupt secure access.

Evidence :

Browser access to <https://demo.testfire.net/?mode=demo> displayed a certificate date warning.

Recommended Fix :

- Renew the TLS certificate before expiry.
- Enable certificate expiry monitoring.
- Verify the certificate chain after renewal.

```
apple@APPLEs-MacBook-Pro ~ % curl -I "https://demo.testfire.net/?mode=demo"  
curl: (60) SSL certificate problem: certificate has expired  
More details here: https://curl.se/docs/sslcerts.html
```

```
curl failed to verify the legitimacy of the server and therefore could not  
establish a secure connection to it. To learn more about this situation and  
how to fix it, please visit the web page mentioned above.
```

```
apple@APPLEs-MacBook-Pro ~ % █
```


F-02 — SECURITY HEADERS NOT OBSERVED

Risk: Medium

Observation:

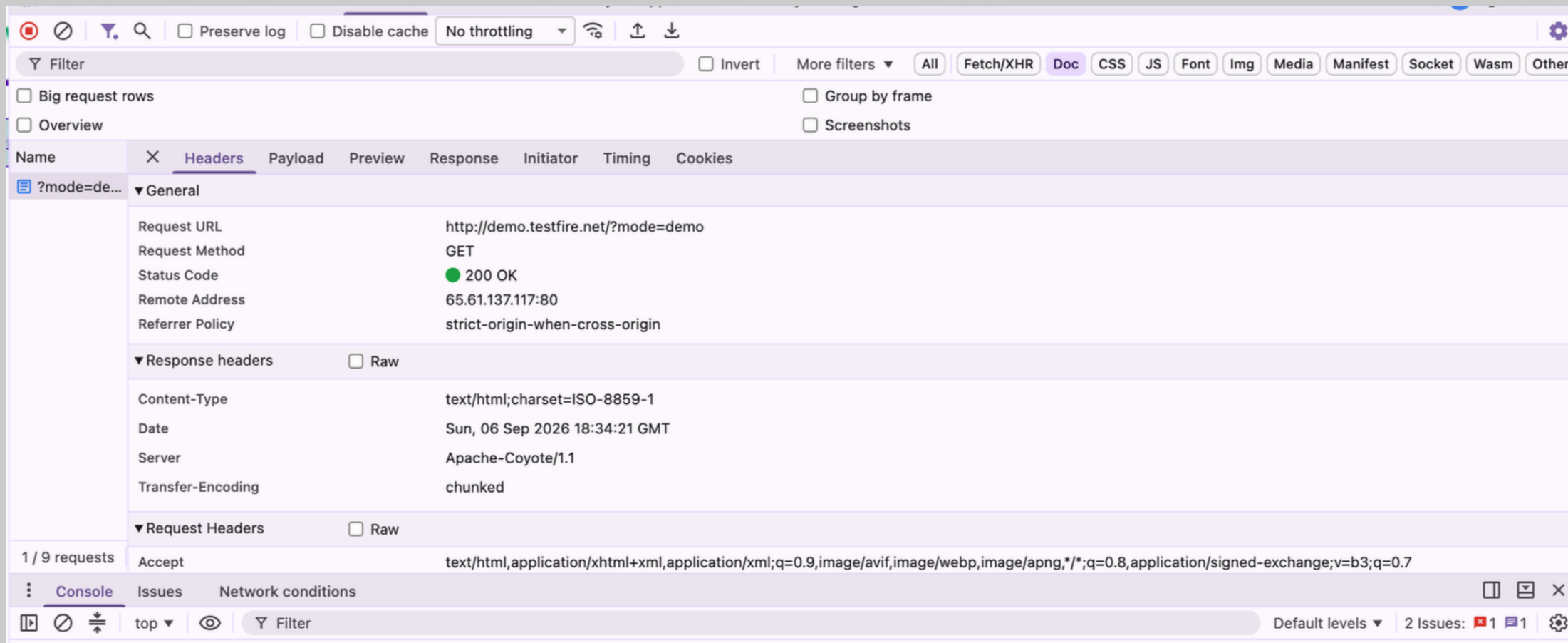
Several recommended security headers were not observed in the captured HTTP response, including Content-Security-Policy, X-Content-Type-Options, X-Frame-Options, and Strict-Transport-Security.

Impact:

Missing security headers can reduce browser-side protection against attacks such as clickjacking, content injection, and unsafe browser behavior.

Recommendation:

Configure appropriate security headers at the web server or application layer and verify them consistently across responses.



F-04 — TCP/8080 Externally Visible

Risk: Low

Observation:

Nmap identified TCP port 8080 as open and associated it with an HTTP proxy service.

Impact:

An externally accessible service increases the exposed attack surface and should be reviewed to ensure it is required and securely configured.

Recommendation:

Confirm whether port 8080 is required. If unnecessary, restrict or close it. If required, apply appropriate access controls and secure configuration.

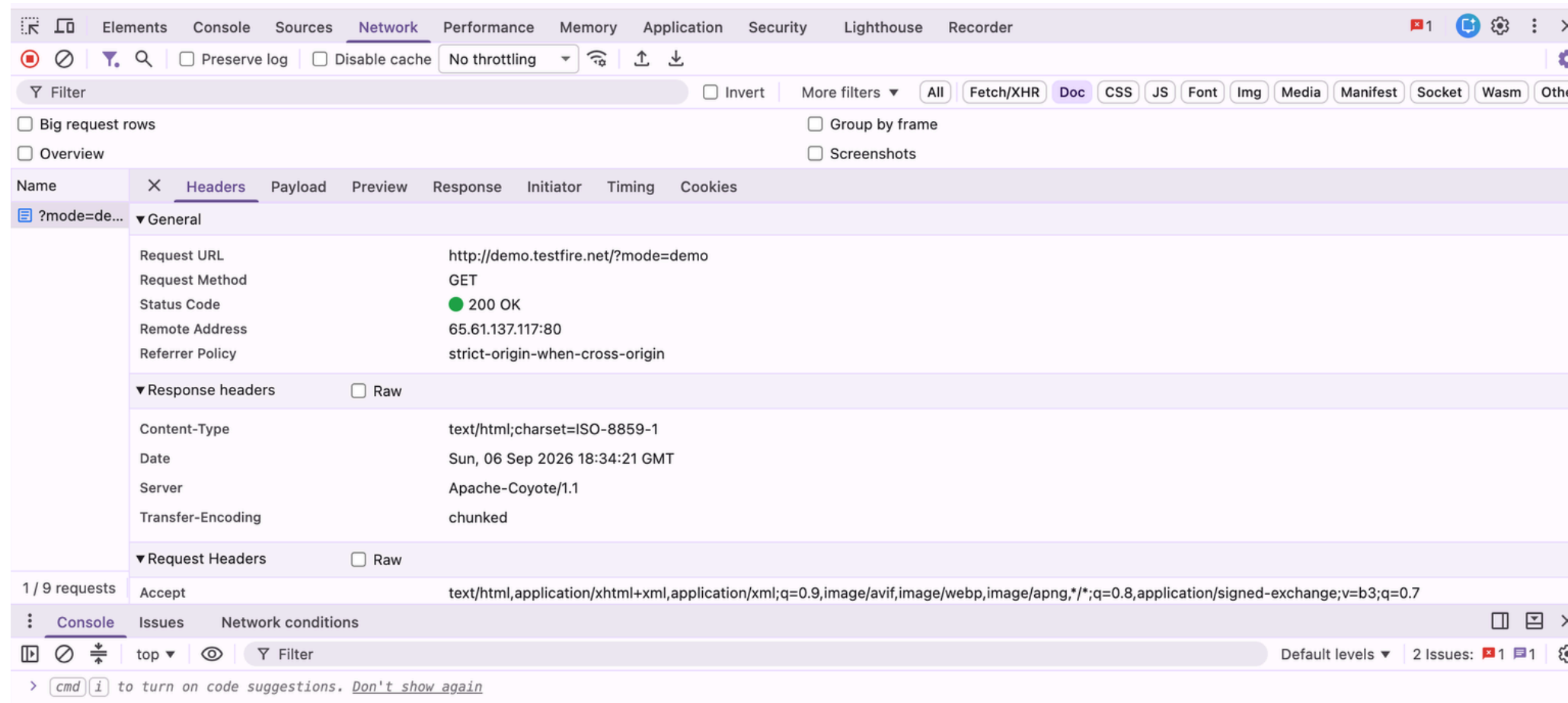
```
[apple@APPLEs-MacBook-Pro ~ % curl -k -I "https://demo.testfire.net/?mode=demo"
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=793E7F0B7C4F4311A580AAD655E3D381; Path=/; Secure; HttpOnly
Content-Type: text/html; charset=ISO-8859-1
Transfer-Encoding: chunked
Date: Sun, 06 Sep 2026 18:26:18 GMT
```

```
apple@APPLEs-MacBook-Pro ~ % nmap -sT -Pn --top-ports 20 demo.testfire.net
[Starting Nmap 7.991 ( https://nmap.org ) at 2026-09-06 23:57 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.30s latency).
```

PORT	STATE	SERVICE
21/tcp	filtered	ftp
22/tcp	filtered	ssh
23/tcp	filtered	telnet
25/tcp	filtered	smtp
53/tcp	filtered	domain
80/tcp	open	http
110/tcp	filtered	pop3
111/tcp	filtered	rpcbind
135/tcp	filtered	msrpc
139/tcp	filtered	netbios-ssn
143/tcp	filtered	imap
443/tcp	open	https
445/tcp	filtered	microsoft-ds
993/tcp	filtered	imaps
995/tcp	filtered	pop3s
1723/tcp	filtered	pptp
3306/tcp	filtered	mysql
3389/tcp	filtered	ms-wbt-server
5900/tcp	filtered	vnc
8080/tcp	open	http-proxy

```
Nmap done: 1 IP address (1 host up) scanned in 9.96 seconds
```

F-05 — Server Technology Disclosure



Risk: Low

Observation:

The HTTP response reveals the server technology through the Server header: Apache-Coyote/1.1.

Impact:

Technology disclosure can provide attackers with useful information for reconnaissance and targeted attack research.

Recommendation:

Minimize or remove unnecessary server technology information from HTTP response headers.

F-06 — Cookie Attribute Inconsistency

Request Cookies

☐ show filtered out request cookies

Name	Value	Domain	Path	Expires ...	Size	HttpOnly	Secure	SameSite	Partitio...	Cross S...	Priority
JSESSIONID	1055...	demo.t...	/	Session	42	✓					Medium

Risk: Low

Observation:

The HTTP response showed the JSESSIONID cookie without the Secure and SameSite attributes. The HttpOnly attribute was present.

Impact:

Inconsistent cookie security attributes may increase the risk of session exposure or unintended cross-site cookie transmission.

Recommendation:

Configure session cookies with Secure, HttpOnly, and an appropriate SameSite attribute, and verify the configuration across HTTP/HTTPS responses

CONCLUSION

The vulnerability assessment identified several security configuration and exposure issues on the target application.

The most significant observations were the expired TLS certificate, missing security headers in the captured response, and availability of HTTP access.

Additional low-risk findings included TCP/8080 exposure, server technology disclosure, and cookie attribute inconsistency.

No exploitation, brute-force, authentication bypass, or destructive testing was performed.

Implementing the recommended remediations would improve the application's security posture and reduce its exposed attack surface.

THANK YOU

